

Ransomware Infection in a Financial Institution

Methods and Data Analytics for Risk Assessment - 20656

Casaleggi Elena - 3319326
Fatigati Veronica - 3151595
Lo Giudice Matteo - 3303092
Salutari Tommaso - 3173886

1 Introduction

Ransomware attacks have emerged as one of the most pressing cybersecurity threats facing financial institutions today, posing significant operational, financial, and reputational risks. Given the complex nature of technical systems and human behaviors in these institutions, understanding and quantifying the impact of internal security practices and employee behavior on ransomware susceptibility is crucial.

This study addresses the critical question: *"How do internal security practices and employee behavior influence the probability and consequences of a successful ransomware attack on a financial institution?"*. To investigate this, we developed a Bayesian network using *AgenaRisk* (project downloadable [here](#)), capitalizing on its capabilities to handle complex interdependencies, incorporate uncertainty through probabilistic reasoning, and visually represent causal relationships clearly and intuitively.

Our approach began with defining a comprehensive ransomware risk pathway, from phishing email reception to eventual business impacts. This pathway was then systematically translated into a structured Bayesian network, linking triggers, controls, consequences, and mitigations. Due to confidentiality constraints and the inherent scarcity of incident-specific data, our model employs a hybrid parameterization method, combining expert elicitation and industry benchmarks. We utilized conditional probability tables (CPTs), populated with both team judgments and public statistics, while acknowledging key uncertainties explicitly.

Through this model, various scenarios were simulated, enabling proactive exploration of risk reduction strategies and sensitivity analysis of different cybersecurity controls and mitigation measures. Ultimately, the goal of this research is to facilitate targeted, data-informed decision-making for enhancing cybersecurity resilience in financial institutions.

2 The Model

2.1 Variables and Node Types

Our Bayesian network, presented visually in the appendix (shown in Figure 1), comprises distinct nodes structured to model ransomware infection risks accurately within financial institutions. Each node was carefully selected and justified according to its specific role and characteristics.

The **trigger variables** include *Phishing Email* and *Employee Clicks Link*, both represented as Boolean nodes. The Phishing Email node (Boolean) represents whether emails received are phishing attempts, with an estimated malicious email rate of 1.2% based on industry benchmarks [StationX \(2024\)](#), [Ozsahan et al. \(2024\)](#). The Employee Clicks Link node (Boolean) captures employee behavior conditional on email type. Specifically, we applied a conditional click rate of 26.6% for phishing emails, as derived from the previously cited source. Conversely, we assumed a significantly higher click rate of approximately 98% for legitimate, non-phishing emails, reflecting typical employee behavior towards routine, work-related communication. This conditional approach results in an aggregated probability of clicking links that accurately represents typical workplace dynamics. The Boolean format was chosen for its simplicity and clear representation of binary outcomes.

The **risk event** node, *Ransomware Infection* (Boolean) is influenced directly by employee actions and institutional controls. The likelihood of infection varies considerably, contingent on the interplay of controls such as EDR Readiness, Cybersecurity Awareness, and Patch Management. For example, a poorly controlled scenario (low awareness, outdated patching, low EDR readiness) combined with employee click yields an infection probability as high as 85%, whereas an optimally controlled scenario significantly reduces the infection probability, often to as low as 5%.

The effectiveness of cybersecurity **controls** is modeled through three ranked nodes:

- *EDR Readiness* (Ranked): Probability distribution of 10% low, 20% medium, and 70% high, representing typical maturity levels observed in the financial sector.
- *Cybersecurity Awareness Level* (Ranked): Distribution set at 30% low, 60% medium, and 10% high, reflecting varying degrees of employee cybersecurity training influenced by regulatory pressures.
- *Patch Management Status* (Ranked): Probability of being outdated at 15%, delayed at 25%, and updated at 60%, capturing typical institutional patching practices.

The potential **consequences** are modeled with three Boolean nodes and one ranked node:

- *Internal Systems Infected* (Boolean): Highly dependent on the ransomware infection and IRP effectiveness.

For example, with poor IRP effectiveness, the probability of internal system infection post-ransomware event is extremely high (99%), whereas good IRP effectiveness significantly reduces this probability to 60%.

- *Transaction Systems Frozen* (Boolean): Directly contingent on internal systems being infected, with a 90% chance of systems freezing if infections occur, highlighting operational vulnerabilities.
- *Customer Data Breach* (Boolean): Dependent on both internal system infections and the encryption type used. With no encryption, a data breach is certain (100%), while AES reduces this probability significantly to 50%, even when internal systems are compromised.
- *Reputational Damage* (Ranked): Evaluated through three severity levels (low, medium, high), heavily influenced by the customer data breach status, transaction system disruptions, and regulatory penalties. High regulatory penalties combined with customer data breaches typically result in significant reputational harm.

Three nodes represent institutional **mitigation** strategies:

- *IRP Effectiveness* (Ranked): Distributed as poor (10%), fair (30%), and good (60%), reflecting the typical state of incident response plans across financial institutions.
- *Data Encryption Type* (Labelled): AES encryption is predominant (90%), followed by DES (9%) and no encryption (1%), realistically capturing current industry standards.
- *Regulatory Penalty* (Ranked): Probabilities are set as low (15%), medium (35%), and high (50%), considering the potential severity and frequency of compliance issues in finance, particularly under GDPR regulations.

2.2 Structure and Links of the Model

The logical structure of our Bayesian network reflects causality inherent in ransomware attack scenarios. The *Phishing Email* node is directly linked to *Employee Clicks Link*, representing the sequential nature of phishing threats, where employees must first receive and then interact with a malicious email.

The *Ransomware Infection* node is directly influenced by employee behavior and institutional cybersecurity controls, capturing the immediate consequence of employee interaction with potential threats. Notably, the ransomware infection directly leads only to the *Internal Systems Infected* node, reflecting that system compromise is the initial critical consequence of ransomware activation. Subsequent nodes, such as *Transactions Frozen* and *Customer Data Breach*, are modeled as consequences contingent upon the status of internal system compromise, emphasizing the cascading effect of cyberattacks within an organization's operations.

The mitigation nodes *IRP Effectiveness*, *Data Encryption Type*, and *Regulatory Penalty* are strategically linked to specific consequence nodes to illustrate their moderating impact. *IRP Effectiveness* directly mitigates the impact of *Internal Systems Infected*, demonstrating the importance of robust response plans in containing cyber incidents. Similarly, the *Data Encryption Type* mitigates the likelihood of a *Customer Data Breach*, underlining the role of strong encryption standards in safeguarding sensitive information. The *Regulatory Penalty* node is connected to *Reputational Damage*, reflecting that legal and compliance repercussions significantly amplify reputational harm following cyber incidents.

2.3 Assumptions and Calibration

Our model assumptions are consciously reflective of practical financial sector insights.

We assumed typical rates and distributions of cybersecurity readiness (EDR, patch management, and awareness) based on sector observations and external data¹. Consequence probabilities are conditional on system states, logically assuming higher impacts with poor mitigations. Regulatory penalties were set based on typical compliance scenarios seen in practice, while encryption and IRP effectiveness probabilities reflect industry-standard practices and regulatory expectations.

These deliberate assumptions enable our model to deliver realistic and meaningful insights into ransomware risks and mitigation effectiveness.

3 Weaknesses of the Model

3.1 Information Not Available

When developing our Bayesian network, certain crucial information remained inaccessible, inherently limiting the scope of our model. Firstly, we lacked detailed insight into attackers' targeting criteria. Specifically, our model does not reflect the decision-making processes or the strategic reasoning behind selecting a financial institution as a target for ransomware. Moreover, the absence of data regarding attacker identities or profiles further restricts our ability to precisely estimate the likelihood of attacks. Although adopting a generalized threat perspective enhances our model's broad applicability, it also inhibits capturing variations arising from attacker-specific capabilities, motives, or strategic behaviors.

Additionally, our model could not incorporate the psychophysical state of employees at the moment of phishing email arrival. Factors such as stress, fatigue, distraction, or cognitive overload play significant roles in whether an employee identifies or mistakenly interacts with malicious

¹ As external data sources, we consider Statista reports, Digital Operational Resilience Act (DORA), General Data Protection Regulatory (GDPR), and European Union Agency for Cybersecurity (ENISA) reports.

content. These human conditions, highly volatile and inherently subjective, remain unmeasurable through standard data collection methods. Thus, even institutions with mature cybersecurity awareness programs cannot reliably predict the human factor's influence at critical moments, introducing persistent uncertainty.

Lastly, our model excludes the complexities of third-party vendor dependencies. Modern financial institutions frequently grant external vendors privileged access to their internal systems for IT support, software integrations, and operational management. Compromise through these third-party relationships represents an alternative attack pathway, potentially bypassing conventional entry points modeled by phishing emails. The absence of detailed supply-chain security data and specific vendor access information prevents explicitly modeling this critical attack vector, thereby limiting the completeness of our risk assessments.

3.2 Omitted Important Variables

Several significant variables were deliberately omitted from our model to maintain manageable complexity, although including them could provide a richer and more realistic depiction of cybersecurity dynamics. For instance, email filtering capabilities, if effectively implemented, significantly reduce the probability of phishing emails ever reaching employee inboxes, thus substantially mitigating ransomware activation risk. Similarly, frequent and comprehensive cybersecurity training could directly improve employee vigilance and reduce successful phishing interactions.

Furthermore, the presence of reliable and regularly updated backup systems greatly influences an organization's resilience by facilitating rapid recovery, thereby reducing operational disruption and reputational damage. The effectiveness of an organization's incident response, notably measured by Mean Time to Detect and Respond (MTTD/MTTR), could critically limit ransomware propagation, minimizing both immediate and long-term consequences.

Finally, timely and transparent internal and external communications during an incident greatly affect public perception, trust retention, and regulatory scrutiny, significantly influencing reputational outcomes and potential regulatory penalties. By omitting these factors, our model simplifies reality at the expense of fully capturing the intricacies of cybersecurity incident dynamics.

3.3 Mismeasurement Issues

Certain mismeasurement issues arise naturally from the generalized design of our Bayesian network, chosen explicitly for broad applicability across diverse financial institutions. This design inherently trades granularity and specificity for flexibility and universal relevance. A notable example of this trade-off is the categorization of cybersecurity

awareness into fixed levels: Low, Medium, High. This simplification enables model scalability and interpretability but overlooks the nuanced variations in organizational cultures, training effectiveness, recent threat exposures, and role-specific cybersecurity responsibilities.

Similarly, representing the customer data breach as a binary variable, rather than differentiating by data sensitivity or type, simplifies the logic and interpretability of the model. However, it neglects important distinctions in the actual severity and consequences of breaches involving different types of compromised information such as personal identifiable information (PII), financial credentials, or transaction logs. Although this abstraction enables clearer inference and outcome propagation, it necessarily reduces the precision of impact assessment in realistic scenarios.

3.4 Impact of Assumptions

Critical assumptions embedded within our model significantly shape its interpretation and outcomes. Structurally, positioning the *Phishing Email* node before *Employee Clicks Link* reflects a causally coherent and logical sequence, matching real-world timelines of phishing incidents. This assumption enables a clear distinction between technical filtering measures and human interactions, enhancing scenario accuracy and interpretability.

Moreover, our decision to exclude ransom payment dynamics from the model deliberately narrows its scope, focusing exclusively on internal organizational and technical consequences. This choice reflects real-world variability and complexity surrounding ransom payment decisions, influenced by legal, ethical, and operational factors differing widely between institutions. Although maintaining clarity and interpretability, this assumption potentially leads to an overestimation of the duration or severity of outcomes in scenarios where ransom payments might facilitate quicker recovery.

Ultimately, these assumptions serve to simplify complex realities into manageable, analyzable frameworks, striking a balance between practicality, interpretability, and analytical rigor. Despite the inherent limitations imposed by such assumptions, they provide a robust foundation for generalized risk analysis applicable across varying institutional contexts.

4 Scenarios

4.1 Worst-Case Scenario

The **worst-case scenario** (shown in Figure 2) represents an extreme situation characterized by maximal vulnerabilities, minimal protections, and severe consequences. This scenario assumes *Phishing Email* and *Employee Clicks Link* nodes to be set at 100% true, explicitly modeling conditions where every email received is malicious and each phishing attempt successfully deceives employees. Additionally, all

control nodes, *Cybersecurity Awareness Level*, *EDR Readiness*, and *Patch Management Status*, are deliberately set at their lowest levels (Low Awareness, Low EDR, Outdated Patch Status), drastically amplifying the risk profile.

Further exacerbating the scenario, mitigation nodes are also minimized, with *IRP Effectiveness* set at Poor and *Data Encryption Type* at None. Consequently, *Regulatory Penalty Severity* is at its highest, reflecting stringent regulatory responses expected under these extreme conditions.

Under these assumptions, a cascading failure is evident, as a Ransomware Infection is guaranteed at 100% probability (up from 59.607% in the model). The internal infection rate of systems skyrockets to 99% (compared to 41.665%), directly translating into nearly complete Customer Data Breach probability at 99%, compared to 22.541%). Consequently, the *Transaction Systems Frozen* reaches an alarming 89.1% probability (from 37.499%), and *Reputational Damage* intensifies dramatically, with the probability of high damage reaching 94.05% against 22.198% in the initial model.

This scenario is constructed to highlight the potential ceiling of organizational losses, illustrating the maximum possible financial, operational, and reputational exposure. It surfaces hidden dependencies, emphasizing how a single point of human error coupled with poor control measures can trigger widespread damage. Additionally, it serves to stress-test the organization's risk appetite, aiding leaders in evaluating the adequacy of their reserves, insurance policies, and cybersecurity investments in the face of potentially catastrophic events.

4.2 Best-Case Scenario

Conversely, the **best-case scenario** (shown in Figure 3) represents an idealized state of cybersecurity readiness and resilience. In this scenario, the model is configured with optimal security parameters: high *Cybersecurity Awareness Level*, high *EDR Readiness*, and fully updated *Patch Management Status*. Furthermore, the mitigation factors are enhanced to their highest security levels, with *IRP Effectiveness* set at Good and *Data Encryption Type* employing AES encryption, while *Regulatory Penalty Severity* is set at the lowest level.

Despite assuming a Phishing Email as true to maintain comparability, the enhanced controls drastically reduce the probabilities of subsequent events. Specifically, the likelihood of a Ransomware Infection diminishes substantially to 12.667% (from 59.607% in the model). Consequently, probabilities for *Internal Systems Infected* reduce significantly to 7.6% (from 41.665%), leading to a markedly lower probability of *Customer Data Breach* at merely 3.8% (compared to 22.541%). Ultimately, this sharply limits the likelihood of critical operational disruptions, with *Transaction Systems Frozen* probability dropping to just 6.84% (from 37.499%) and *High Reputational Damage* becoming nearly negligible at 1.026% (from 22.198%).

This scenario aims to showcase the tangible benefits of investing in and maintaining strong cybersecurity measures. By quantifying how mature and effective cybersecurity strategies dramatically mitigate risk, it provides a clear aspirational benchmark. Additionally, it offers a concrete framework for Return on Investment (ROI) discussions, enabling stakeholders to clearly perceive cybersecurity spending as strategic and financially justified. Finally, it builds organizational confidence by demonstrating that ransomware threats can indeed be actively contained and managed rather than merely endured.

Table 1
Comparison of scenarios: Best vs Worst Case

Outcome (%)	Label	Best Case	Worst Case
Ransomware Infection	T	12.67	100.00
	F	87.33	0.00
Internal Systems Infected	T	7.60	99.00
	F	92.40	1.00
Customer Data Breach	T	3.80	99.00
	F	96.20	1.00
Transaction Systems Frozen	T	6.84	89.10
	F	93.16	10.90
Reputational Damage	Low	96.58	1.00
	Medium	2.39	4.95
	High	1.03	94.05

4.3 Controls' Impact – Single Weakness Analysis

This scenario series (shown in Figures 4 5 6) isolates the effect of each individual control by degrading them one at a time while maintaining all other variables at their optimal levels. The goal is to assess which control failure has the most detrimental effect on ransomware propagation and downstream consequences. Specifically, we evaluate the impact of setting the following nodes to their weakest configuration, one at a time:

- **Cybersecurity Awareness Level:** set to *Low*
- **EDR Readiness:** set to *Low*
- **Patch Management Status:** set to *Outdated*

In each case, the rest of the model is held at its standard configuration with the default levels. The results show differentiated impacts depending on which control is weakened, as detailed in Table 2.

The highest degradation in outcome probabilities is observed under **Outdated Patch Management** (Figure 6), which drives the ransomware infection rate up to 68% compared to 59.607% in the model. It also leads to the highest downstream probabilities across all categories, indicating that patching plays a crucial systemic role in containment. Conversely, while **Low Cybersecurity Awareness** (Figure 4) still increases risk significantly, it results in the lowest

Table 2
Impact of weakening individual Controls

Outcome (%)	Low Awareness	Low EDR	Outdated Patch
Ransomware Infection	53.43	63.14	68.00
Internal Systems Infected	37.35	44.14	47.53
Customer Data Breach	20.21	23.88	25.72
Transaction Systems Frozen	33.61	39.72	42.80
High Reputational Damage	19.90	23.52	25.32

shift among the three, suggesting that even with human error, strong technical controls can help buffer impacts.

This scenario is designed to pinpoint the most impactful single points of failure in the institution's security posture. By altering one control at a time, it surfaces weakest-link dynamics, identifying which lapses most severely erode protection. These findings help prioritize security investments by maximizing marginal returns, guiding institutions to achieve rapid and efficient risk reduction even under resource constraints.

4.4 Mitigations' Effectiveness Scenario

The fourth scenario examines how variations in post-infection mitigations influence the severity of consequences, even when upstream triggers and controls remain unchanged. To isolate the impact of containment strategies, the *Ransomware Infection* node is explicitly set to true, simulating a successful breach. All other variables are left with their original model distributions. What changes across the three cases are the mitigation nodes: **IRP Effectiveness** and **Data Encryption Type**, set at Poor/None, Fair/DES, and Good/AES, respectively.

In the first configuration (shown in Figure 7), with *IRP Effectiveness* at **Poor** and *Data Encryption Type* set to **None**, the consequences mirror those of a nearly uncontrolled incident. The probability of *Internal Systems Infected* reaches 99%, *Customer Data Breach* also peaks at 99%, and *Transaction Systems Frozen* rises sharply to 89.1%. The reputational toll is severe as well, with *Reputational Damage* occurring at 68.013%. This configuration underscores how weak mitigations allow damage to propagate without meaningful containment.

With moderate improvements (shown in Figure 8), *IRP Effectiveness* at **Fair** and *Encryption* set to **DES**, the damage is partially reduced. *Internal Systems Infected* decreases to 80%, *Customer Data Breach* drops to 72%, and *Transaction Systems Frozen* falls to 72%. The probability of *Reputational Damage* also declines to 52.272%. These results demonstrate that even intermediate mitigations substantially reduce the blast radius of a ransomware event.

Under optimal mitigation settings (shown in Figure 9), where *IRP Effectiveness* is set to **Good** and *Encryption* uses **AES**, outcomes improve further. *Internal Systems Infected*

decreases to 60%, *Customer Data Breach* is limited to 30%, and the probability of *Transaction Systems Frozen* drops to 54%. *High Reputational Damage* falls to 31.14%, representing more than a 50% reduction compared to the poorly mitigated case.

This scenario confirms the critical role of post-breach mitigations in capping impact once an infection has occurred. It quantifies the effectiveness of incident response planning and data protection, justifying their prioritization even in environments with limited prevention budgets. Ultimately, it reinforces a layered defense strategy where mitigations act as essential safety nets in containing residual risk.

Table 3
Impact of Mitigations on Consequences

Outcome (%)	Poor/No	Fair/DES	Good/AES
Internal Systems Infected	99.00	80.00	60.00
Customer Data Breach	99.00	72.00	30.00
Transaction Systems Frozen	89.10	72.00	54.00
High Reputational Damage	68.01	52.27	31.14

5 Conclusion

This study quantified how internal security practices and employee behaviour determine the likelihood and impact of a ransomware attack on a financial institution. Using AgenaRisk we built a compact Bayesian network linking triggers, controls, the ransomware risk event, cascading consequences and downstream mitigations. Hybrid parameterisation mixed industry statistics with expert-elicited conditional probability tables, while scenario simulation provided a controlled laboratory for stress-testing the model and comparing counterfactual worlds.

The scenario analysis shows a clear hierarchy of levers. When patch management and EDR readiness are weak the probability of infection rises from the model value of 59.61% to 68.00%, amplifying every downstream impact. Conversely, a best-case control profile drives infection odds down to 12.67% and keeps reputational damage almost negligible at 1.03%. Once infection is forced, strengthening mitigations from poor response and no encryption to a good incident-response plan and AES halves internal system compromise from 99% to 60% and cuts reputational damage from 68.01% to 31.14%. Single-control degradations reveal outdated patching as the most sensitive node, indicating where limited budgets should focus first.

Inevitably the model abstracts from reality. It lacks data on attacker targeting logic, employee stress and third-party supply-chain exposure; it omits variables such as email filtering, backup maturity, detection-and-response times and crisis communication quality; it compresses rich phenomena into coarse scales, for example awareness as Low,

Medium or High and breach as a simple yes-or-no; and it assumes no ransom payment, a choice that may overstate loss duration in pay-to-decrypt cases. Nevertheless, the Bayesian-network methodology remains valuable because it integrates sparse evidence with expert judgement, traces causal pathways transparently and can evolve to incorporate richer attacker models or cost-benefit nodes. Rather than an oracle it serves as a decision-support tool that highlights leverage points, quantifies trade-offs and makes uncertainty explicit, supporting risk-informed governance where perfect data will never be available.

References

European Union (Apr. 2016). *Regulation (EU) 2016/679 of the European Parliament and of the Council on the Protection of Natural Persons with regard to the Processing of Personal Data (General Data Protection Regulation)*. Official English version of the GDPR. URL: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32016R0679>.

— (Dec. 2022). *Regulation (EU) 2022/2554 of the European Parliament and of the Council on Digital Operational Resilience for the Financial Sector (DORA)*. Official English version of the DORA Regulation. URL: <https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32022R2554>.

European Union Agency for Cybersecurity (ENISA) (Feb. 2024). *Threat Landscape for the Finance Sector - 2024*. URL: https://www.enisa.europa.eu/sites/default/files/2025-02/Finance%20TL%202024_Final.pdf.

Ozsahan, Hatice and David Worthington (Apr. 2024). *50+ Phishing Attack Statistics for 2025*. URL: <https://jumpcloud.com/blog/phishing-attack-statistics>.

StationX (Dec. 2024). *Top Phishing Statistics for 2025: Latest Figures and Trends*. URL: <https://www.stationx.net/phishing-statistics/>.

Statista (Dec. 2024). *Phishing - Statistics & Facts*. URL: <https://www.statista.com/topics/8385/phishing/#topicOverview>.

Appendix

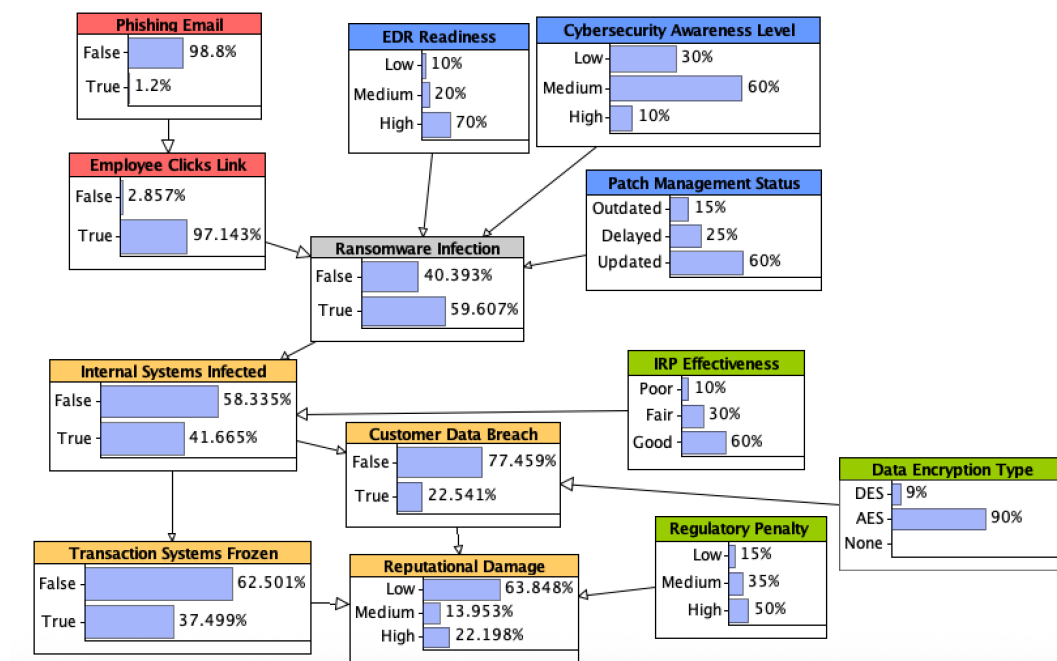


Figure 1. The Model

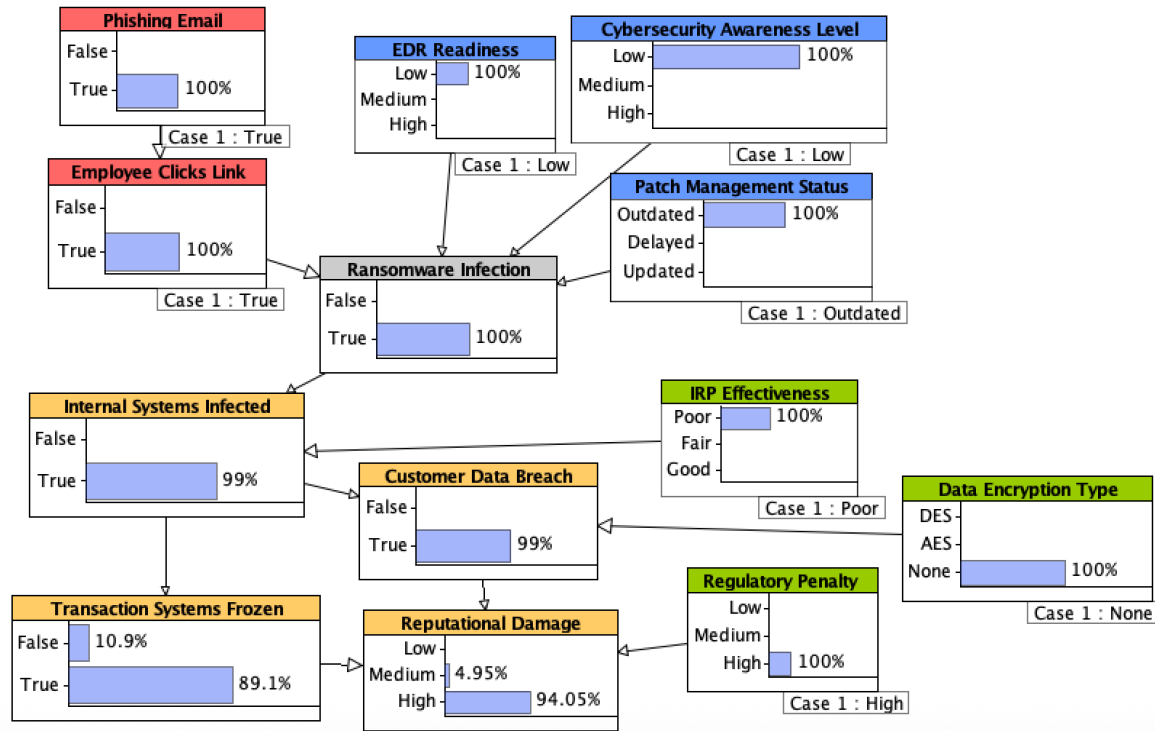


Figure 2. Worst-Case Scenario Output

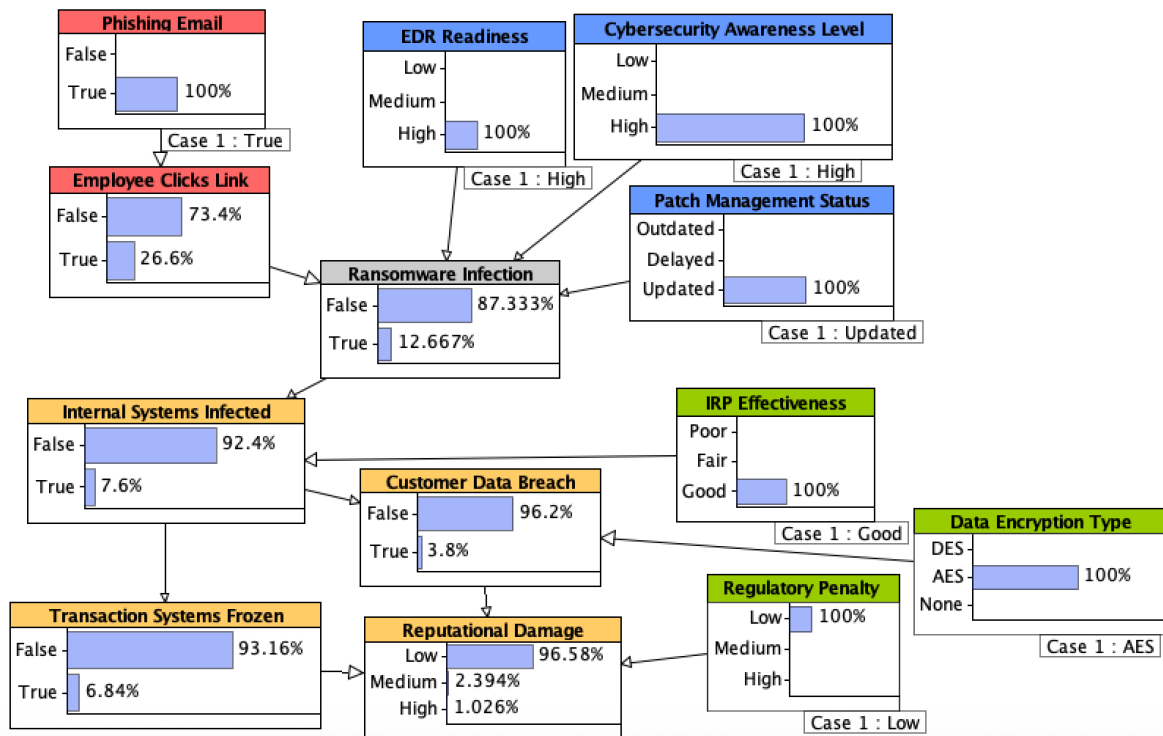


Figure 3. Best-Case Scenario Output

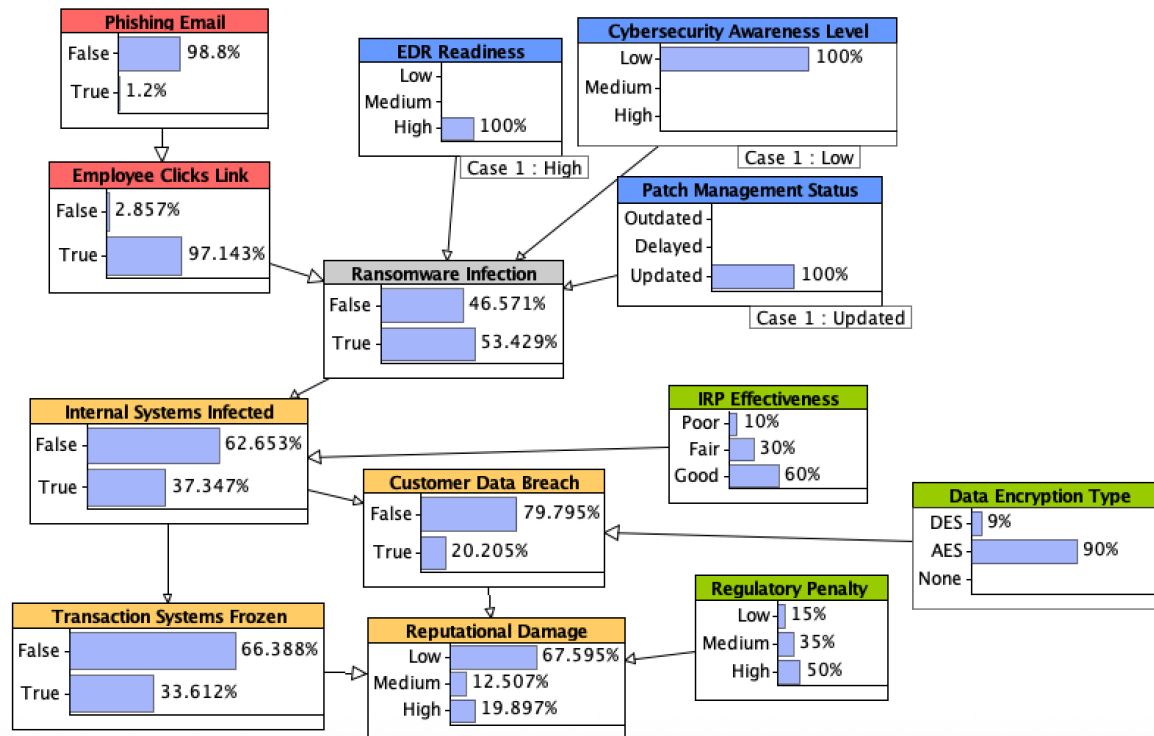


Figure 4. Low Cybersecurity Awareness

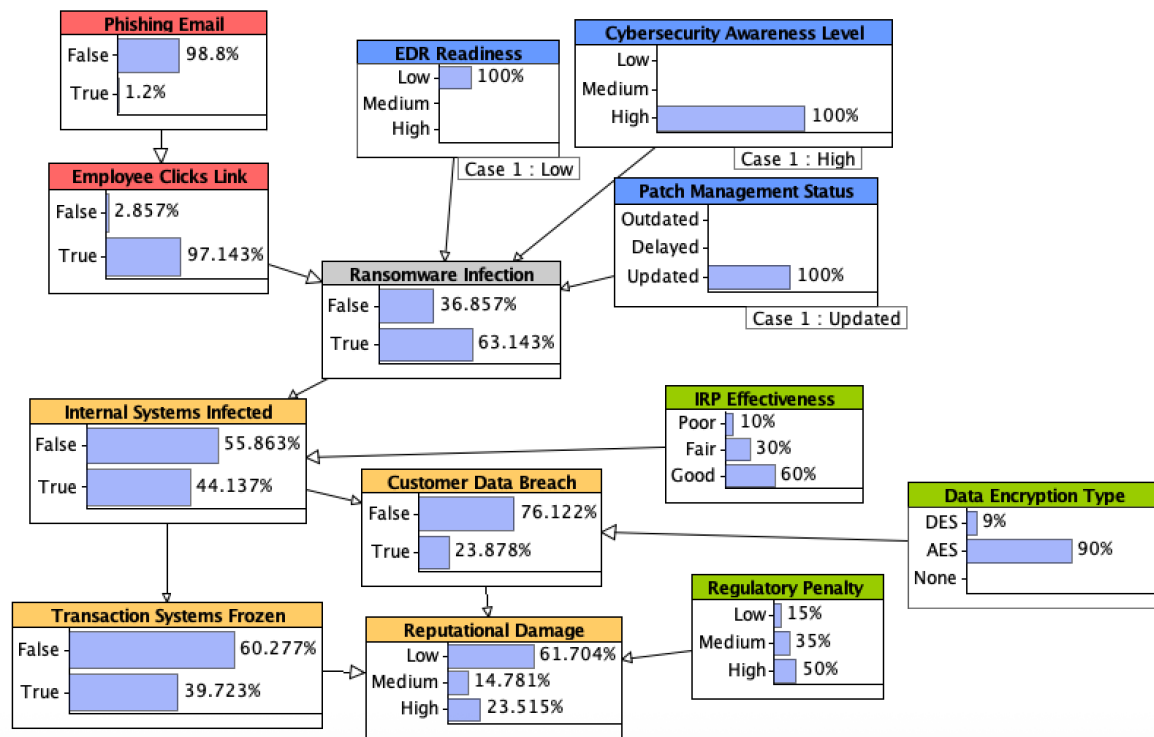


Figure 5. Low EDR Readiness

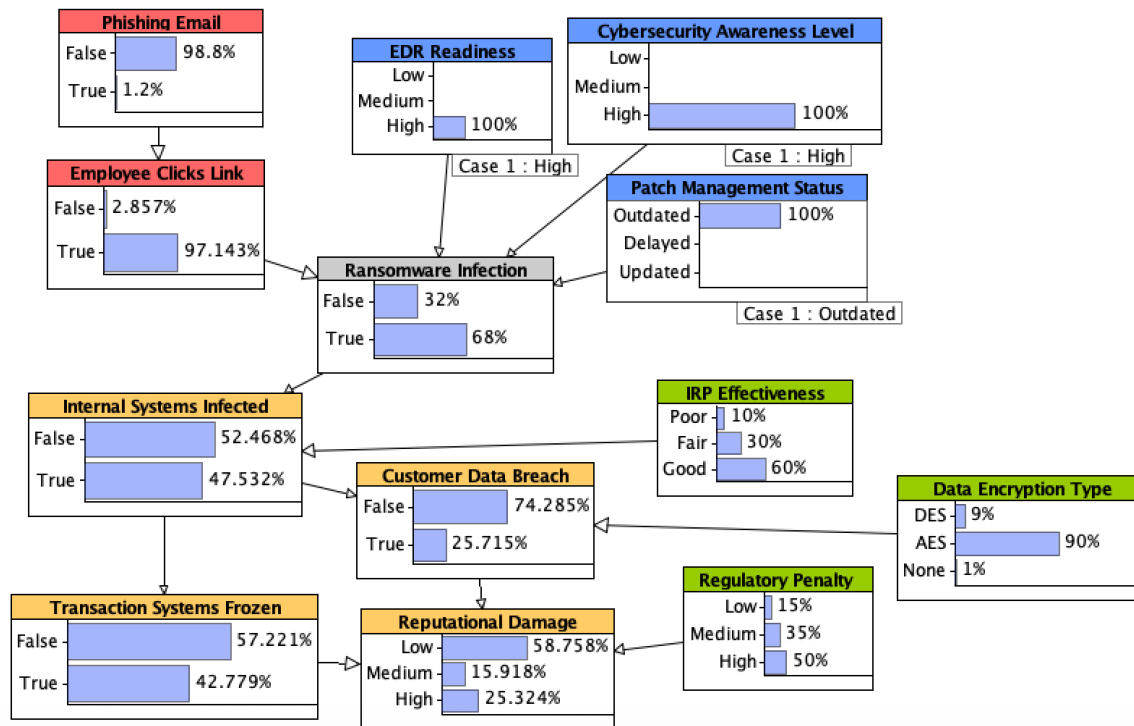


Figure 6. Outdated Patch Management

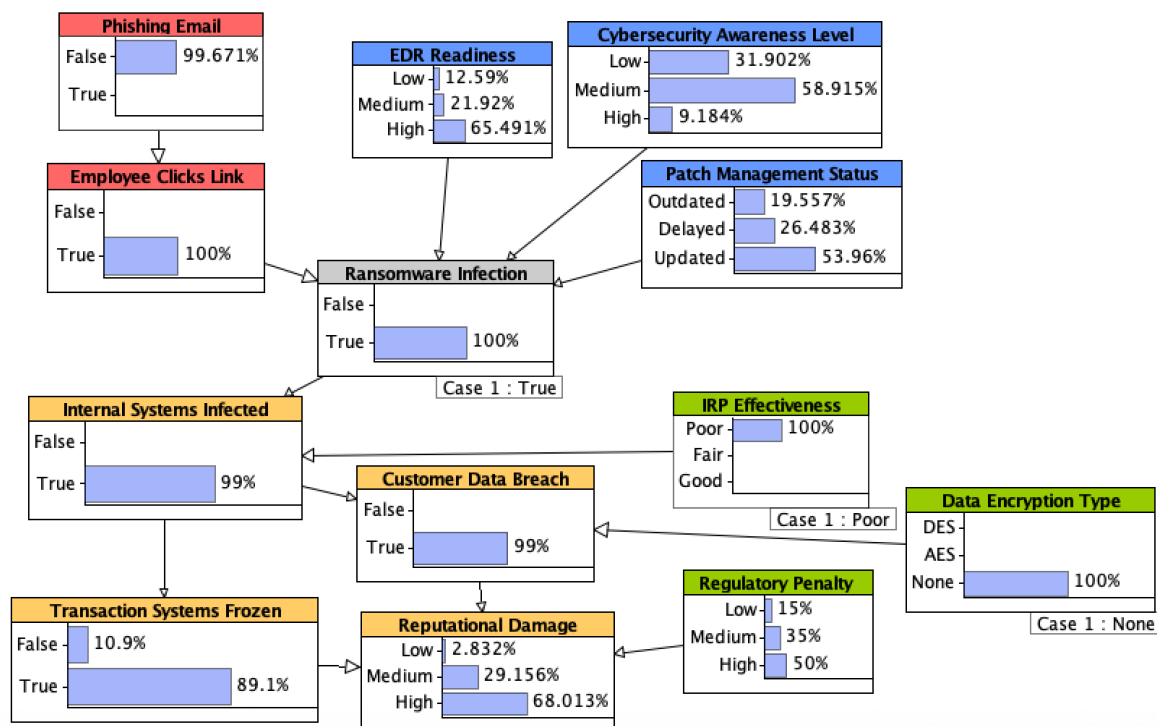


Figure 7. Poor/None Mitigations

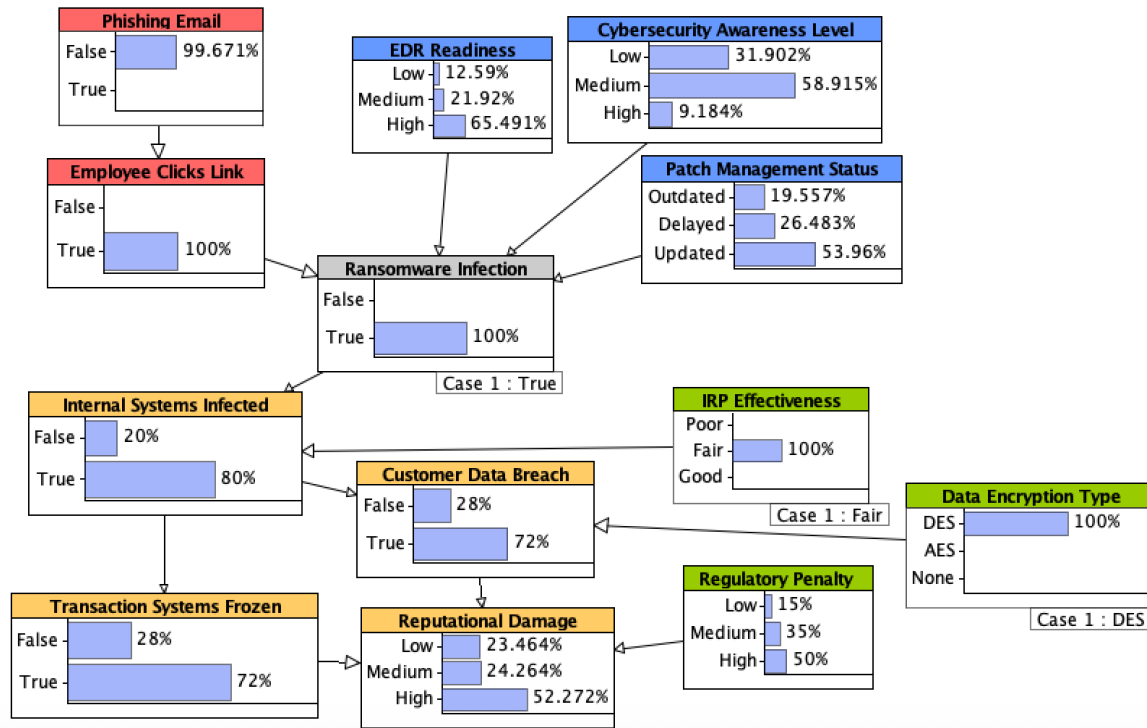


Figure 8. Fair/DES Mitigations

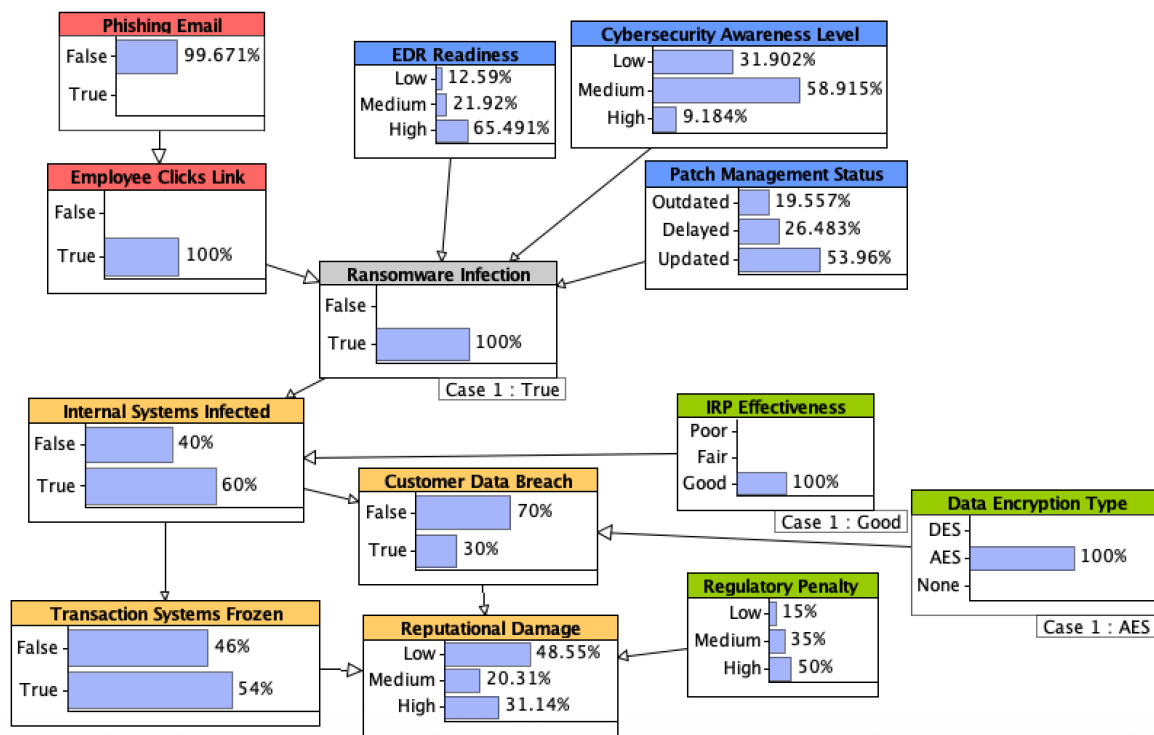


Figure 9. Good/AES Mitigations